Lab 5: Static Code Analysis

Sports Tournament Scoreboard (tournament_scoreboard.py)

Field	Details
Name	SAIKAVIN S
SRN	PES1UG24CS402
Section	5G
Course	Software Engineering Lab
Date	30/10/2026
GitHub repository	https://github.com/Saikavin-S/SE-LABS-PES1UG24CS402 (folder: LAB 5)

1. Objective

To run three static analysis tools (Pylint, Flake8 and Bandit) on a small Python program, record the issues they report, fix them step by step with one Git commit per stage, and compare the reports before and after.

2. Introduction to Static Code Analysis

Static code analysis examines source code without running it. Automated tools read the code and flag bugs, security weaknesses, style violations and maintainability problems early, when they are cheapest to fix. It complements testing: tests check behaviour on chosen inputs, while static analysis checks every line, including paths the tests never execute. Its limit is that it cannot know what the program is meant to do, so a clean report does not prove the code is correct.

Three tools were used in this lab:

- Pylint: a general code-quality checker. It reports naming problems, missing docstrings, risky patterns such as mutable default arguments and refactoring hints, and gives the code a score out of 10.
- Flake8: a style checker that enforces PEP 8 formatting rules (spacing, blank lines, line length) and finds unused imports and variables.
- Bandit: a security scanner for Python. It reports weak or dangerous patterns such as shell command construction, insecure temporary files, hardcoded secrets and non-cryptographic random numbers, each with a severity and confidence level.

3. Tools and Procedure

Tool	Checks for	Command used
Pylint	Code quality, naming, docstrings, likely bugs	python -m pylint tournament_scoreboard.py
Flake8	PEP 8 style and formatting	python -m flake8 tournament_scoreboard.py
Bandit	Security vulnerabilities	python -m bandit -r tournament_scoreboard.py

Steps followed: run the original program, generate the three "before" reports and commit them, fix the Bandit findings, fix the Flake8 findings, fix the Pylint findings and logic bugs, regenerate all reports, then write issues.md and reflection.md.

4. Original Program and Before Reports

4.1 Original program output

The program registers four teams, records four matches and prints the league table. The table is the reference output: it must stay the same after every fix. Only the coin toss line is random.

```
saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ python tournament_scoreboard.py
Toss: Heads
Pos Team Played Won Drawn Lost Pts
1 Royal Strikers 2 1 1 0 4
2 City Rovers 2 1 0 1 3
3 Hill Warriors 2 0 2 0 2
4 Lake United 2 0 1 1 1
Is City Rovers in the top two? True
Matches played: 4
```

Figure 1: Original program output (python tournament_scoreboard.py)

4.2 Bandit report (before)

Bandit reported 4 issues: 1 High, 1 Medium and 2 Low (B605, B306, B105 and B311).

```
Run started:2026-10-30 18:14:25.686102+00:00

Test results:
>> Issue: [b105:hardcoded_password_string] Possible hardcoded password: 'referee-demo'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\tournament_scoreboard.py:6:19
5       POINTS = {"win" : 3, "draw": 1, "loss": 0}
6       REFEREE_PASSWORD = "referee-demo"
7       teams = {}

--------------------------------------------------
>> Issue: [b311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\tournament_scoreboard.py:61:11
60      def tosscoin():
61          return random.choice(["Heads", "Tails"])
62

--------------------------------------------------
>> Issue: [b306:blacklist] Use of insecure and deprecated function (mktemp).
   Severity: Medium   Confidence: High
   CWE: CWE-377 (https://cwe.mitre.org/data/definitions/377.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q
   Location: .\tournament_scoreboard.py:66:11
65          # Helper kept for the lab; not called by the demo
66          return tempfile.mktemp(suffix=".json")
 7

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\tournament_scoreboard.py:71:4
70          # Helper kept for the lab; not called by the demo
71          os.system("scp table.json " + server + ":/var/www/")
72

--------------------------------------------------

Code scanned:
        Total lines of code: 66
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 3
Files skipped (0):
```

Figure 2: bandit_before.txt

4.3 Flake8 report (before)

Flake8 reported 4 warnings: E203, E302, E231 and E261.

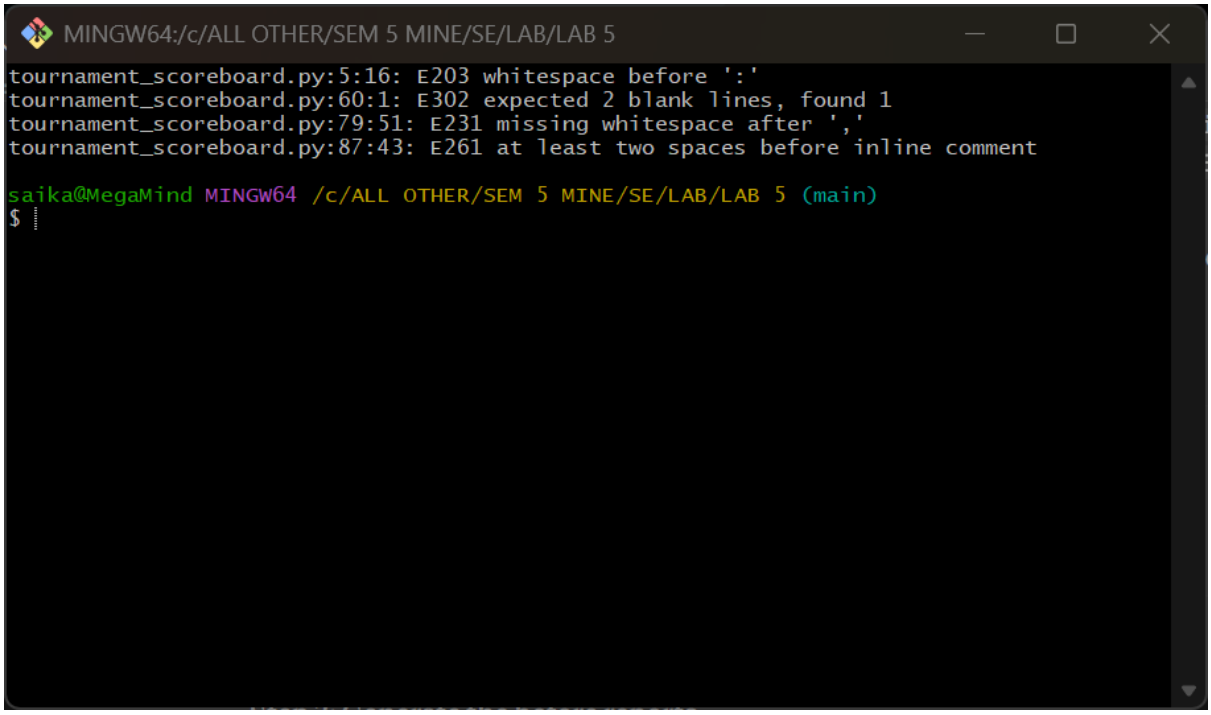


Figure 3: flake8_before.txt

4.4 Pylint report (before)

Pylint rated the code 4.75/10. The messages were mostly missing docstrings and camelCase names, plus W0102 (dangerous default value), R1705 (no-else-return) and R1714 (consider-using-in).

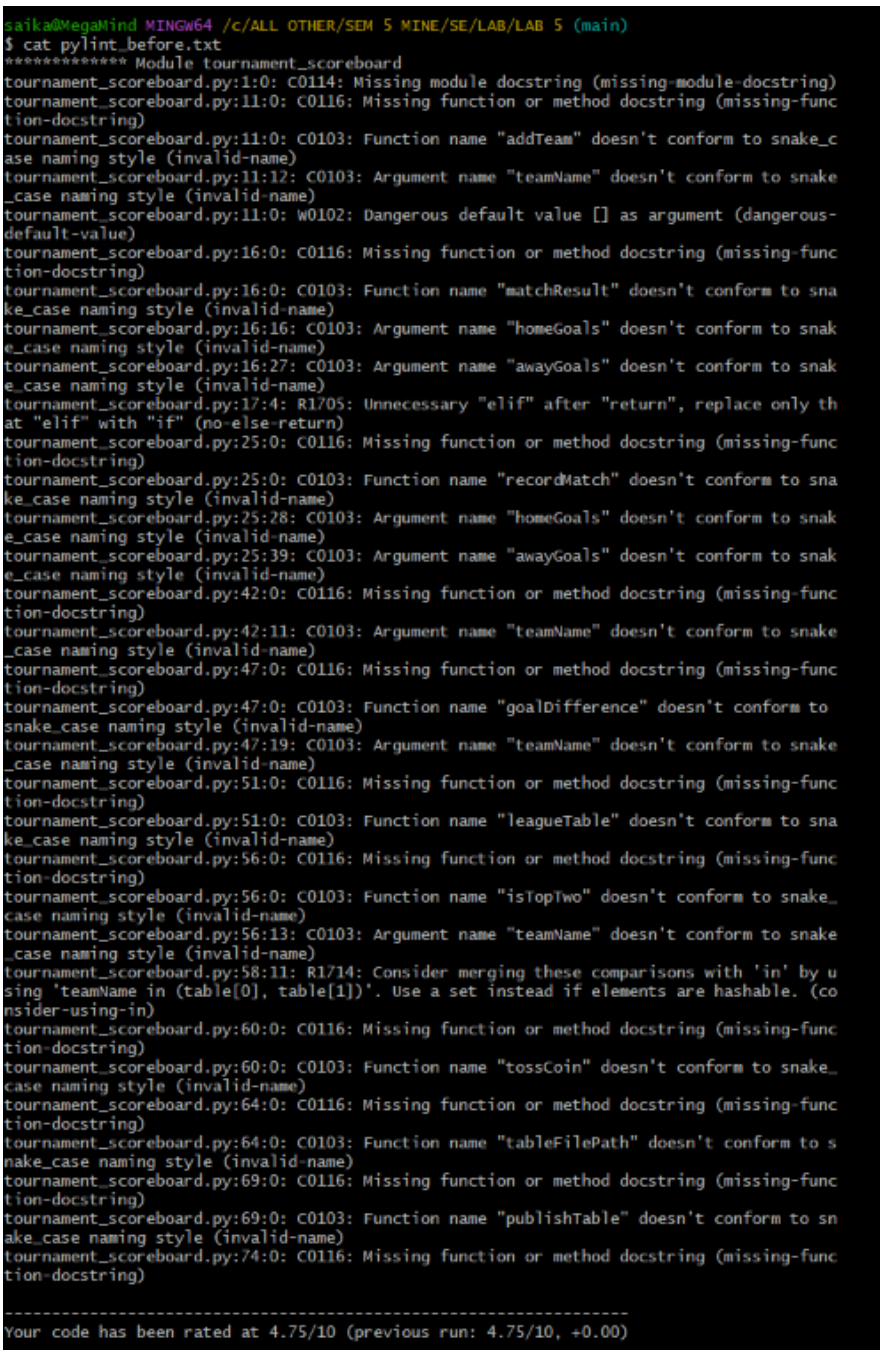


Figure 4: pylint_before.txt (4.75/10)

5. Fixes

5.1 Bandit fixes (commit 2)

- B605: os.system replaced with subprocess.run using an argument list and no shell.
- B306: tempfile.mktemp replaced with tempfile.mkstemp.
- B105: hardcoded password replaced with os.environ.get("REFEREE_PASSWORD").

- B311: random.choice replaced with secrets.choice.
- The new subprocess import and call were marked with # nosec plus a comment, because the arguments are a fixed list and no shell is used.

```
saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ python tournament_scoreboard.py
Toss: Tails
Pos Team Played Won Drawn Lost Pts
1 Royal Strikers 2 1 1 0 4
2 City Rovers 2 1 0 1 3
3 Hill Warriors 2 0 2 0 2
4 Lake United 2 0 1 1 1
Is City Rovers in the top two? True
Matches played: 4

saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ cat bandit_after.txt
Run started:2026-10-30 18:22:49.898284+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 72
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 2

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Figure 5: bandit_after.txt: No issues identified, 2 potential issues skipped by # nosec

5.2 Flake8 fixes (commit 3)

Fixed the spacing in "win": 3, added the missing blank line before the coin toss function, added a space after the comma in the first match call and put two spaces before the inline comment.

```
saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ python tournament_scoreboard.py
python -m flake8 tournament_scoreboard.py > flake8_after.txt
Toss: Tails
Pos Team Played Won Drawn Lost Pts
1 Royal Strikers 2 1 1 0 4
2 City Rovers 2 1 0 1 3
3 Hill Warriors 2 0 2 0 2
4 Lake United 2 0 1 1 1
Is City Rovers in the top two? True
Matches played: 4

saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ cat flake8_after.txt
```

Figure 6: flake8_after.txt: empty output (no warnings)

5.3 Pylint fixes and logic bugs (commit 4)

- Renamed all functions and arguments to snake_case and updated every call.
- Added a module docstring and a docstring for every function.
- Replaced the mutable default players=[] with None (each team gets its own list).
- Replaced elif/else after return with plain if statements.
- Replaced the two-comparison check in is_top_two with team_name in league_table()[:2], which also removes a possible IndexError.

- Added an if __name__ == "__main__": guard so importing the module does not run the demo.

```
saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ python -m pylint tournament_scoreboard.py > pylint_after.txt
python -m bandit -r tournament_scoreboard.py > bandit_after.txt 2>/dev/null
python -m flake8 tournament_scoreboard.py > flake8_after.txt

saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ tail -3 pylint_after.txt
cat flake8_after.txt
cat bandit_after.txt
python tournament_scoreboard.py
-------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.75/10, +5.25)

Run started:2026-10-30 18:25:36.513129+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 87
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 2

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
Toss: Tails
Pos Team Played Won Drawn Lost Pts
1 Royal Strikers 2 1 1 0 4
2 City Rovers 2 1 0 1 3
3 Hill Warriors 2 0 2 0 2
4 Lake United 2 0 1 1 1
Is City Rovers in the top two? True
Matches played: 4
```

Figure 7: Final results: Pylint 10.00/10, empty Flake8, clean Bandit and final program output

6. Issues Table

Line numbers refer to the original file. Security issues are listed first.

#	*Issue*	*Type*	*Line(s)*	*Description*	*Fix approach*
1	Command injection via os.system (B605)	Security (High)	71	os.system("scp table.json " + server + ...) builds a shell command from a string, so a crafted server value can run arbitrary commands.	Replaced with subprocess.run(["scp", ...], check=True): fixed argument list, no shell. Server names starting with "-" are rejected so they cannot be read as scp options.
2	Insecure temp file (B306)	Security (Medium)	66	tempfile.mktemp only returns a name, so another process can create that file first (race condition).	Used tempfile.mkstemp, which creates the file atomically; closed the descriptor and returned the path.
3	Hardcoded password (B105)	Security (Low)	6	REFEREE_PASSWORD = "referee-demo" stores a secret in source code.	Read it from the REFEREE_PASSWORD environment variable.

4	Non-cryptographic random (B311)	Security (Low)	61	random.choice is not suitable for security purposes.	Switched to secrets.choice.
5	Shared mutable default argument (W0102)	Logic bug	11	players=[] is created once, so every team added without players shares the same list.	Default is now None and each team gets its own new list.
6	is_top_two can crash (R1714)	Logic bug	56-58	table[0] and table[1] raise IndexError when fewer than 2 teams exist.	team_name in league_table()[:2] works for any number of teams.
7	Demo runs on import	Quality	last line	main() ran whenever the module was imported.	Added an if __name__ == "__main__": guard.
8	Naming style (C0103)	Quality	11-69	camelCase functions and arguments (addTeam, teamName, homeGoals...).	Renamed everything to snake_case at every call site.
9	Missing docstrings (C0114, C0116)	Quality	1 and all functions	No module or function docstrings.	Added docstrings.
10	Unnecessary elif after return (R1705)	Quality	17	elif/else after return in matchResult.	Used plain if statements.
11	Whitespace before ':' (E203)	Style	5	"win" : 3	"win": 3
12	Blank lines (E302)	Style	60	Only one blank line before tossCoin.	Two blank lines.
13	Missing whitespace after ',' (E231)	Style	79	2,1	2, 1
14	Inline comment spacing (E261)	Style	87	One space before the inline comment.	Two spaces.

7. Results

Tool	***Before***	***After***
Pylint	4.75/10	10.00/10
Flake8	4 warnings	0 warnings
Bandit	4 findings (1 High, 1 Medium, 2 Low)	No issues (2 suppressed with # nosec and a written reason)
Program output	Table and match count as shown in Figure 1	Identical table and match count (only the coin toss is random)

8. Reflection

1. Which issues were the easiest to fix and which were the hardest?

The Flake8 warnings were the easiest. There were only four, and each one named the exact line: a space before a colon, a missing blank line, a missing space after a comma and an inline comment that needed two spaces. The Pylint naming and docstring warnings were also easy, but there were many of them and every rename had to be applied at every call site.

The hardest were the security fixes, because they needed thought and not just formatting. Replacing os.system meant building an argument list for subprocess.run, and I also had to think about a server name starting with "-" being read as a command-line option. Replacing mktemp with mkstemp changed what the function returns internally, so the file descriptor had to be closed. Fixing the shared players=[] default also required understanding how Python creates default values.

2. Did the tools report any false positives, or miss any real problems?

Bandit's B311 warning about random.choice is close to a false positive, because a coin toss in a scoreboard is not security-sensitive. I still changed it to secrets.choice since that costs nothing. After moving to subprocess, Bandit warned about the import and the call (B404, B603, B607). Here the code is safe: the arguments are a fixed list and no shell is used. I suppressed those with # nosec and a comment explaining why, instead of leaving them unexplained.

The tools also missed things. is_top_two would crash with fewer than two teams, but Pylint only suggested using "in" and never mentioned the IndexError. Bandit saw the shell but not that a server name beginning with "-" could be read as an option by scp. No tool checks that the league table is correct; I only knew the output was right by working out the points by hand.

3. How does static analysis contribute to code quality and maintainability?

The Pylint score went from 4.75/10 to 10.00/10, Flake8 went from 4 warnings to 0, and Bandit went from 4 findings to none. The code is now consistent (snake_case, PEP 8), documented and safer: no shell command built from a string, no predictable temp file and no password in the source. That makes it easier to read and review, and the tools caught problems such as the shared mutable default before the program was ever run.

4. How would you use static analysis in a real project, and what are its limits?

I would run Pylint, Flake8 and Bandit automatically on every commit or pull request (a pre-commit hook or a CI step), and fail the build on any Bandit High or Medium finding or on a Pylint score below a set threshold. Problems found there are cheap to fix.

The limit is that these tools do not know what the program is supposed to do. A clean report does not mean the code is correct, so static analysis has to be combined with unit tests, code review and checking the output. Findings also need judgement: each one should be fixed or suppressed with a written reason, as I did with the # nosec comments.

9. Git History

One commit per stage was pushed to the LAB 5 folder of the repository.

#	***Commit message***	***Files***
1	Lab5: add original program and before reports	tournament_scoreboard.py, 3 _before reports
2	Fix Bandit security issues	tournament_scoreboard.py, bandit_after.txt
3	Fix Flake8 style issues	tournament_scoreboard.py, flake8_after.txt
4	Fix Pylint issues and logic bugs	tournament_scoreboard.py, pylint_after.txt, bandit_after.txt, flake8_after.txt
5	Add issues.md	issues.md
6	Add reflection.md	reflection.md

```
saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ git ls-files
bandit_after.txt
bandit_before.txt
flake8_after.txt
flake8_before.txt
issues.md
pylint_after.txt
pylint_before.txt
reflection.md
tournament_scoreboard.py

saika@MegaMind MINGW64 /c/ALL OTHER/SEM 5 MINE/SE/LAB/LAB 5 (main)
$ git log --oneline -8
6a74389 (HEAD -> main, origin/main) Add reflection.md
0b921c4 Add issues.md
7a8f772 Fix Pylint issues and logic bugs
ebf2328 Fix Flake8 style issues
9ff5953 Fix Bandit security issues
32c0165 Lab5: add original program and before reports
96891bc Update game.py with task 4
1409115 Update game.py with task 3
```

Figure 8: git log --oneline -8 and git ls-files (6 commits, 9 files)

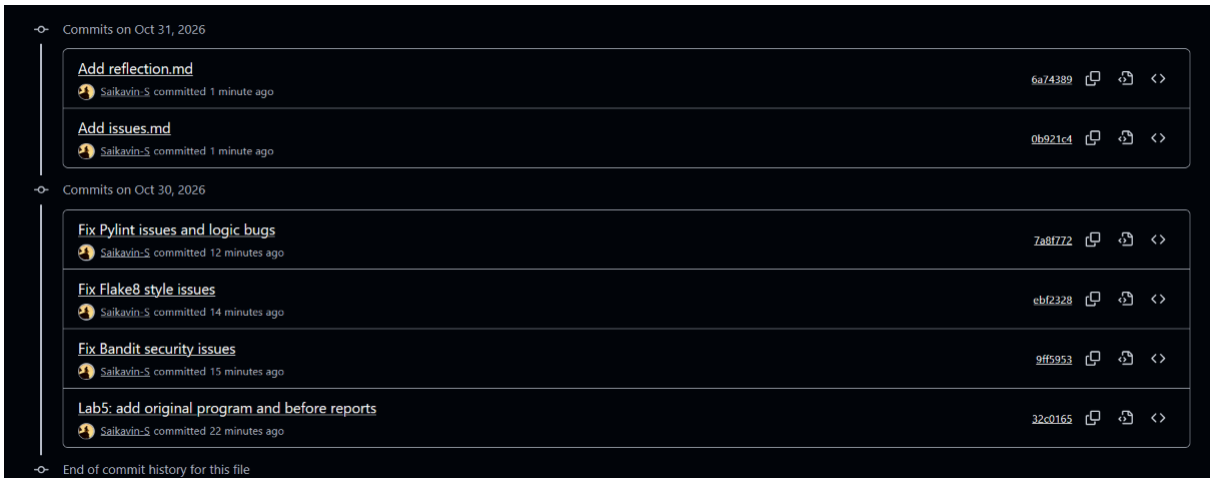


Figure 9: LAB 5 folder on GitHub showing all 9 files

10. Appendix: Contents of All Six Reports

The text below is copied unchanged from the six report files.

10.1 pylint_before.txt

```
************* Module tournament_scoreboard
tournament_scoreboard.py:1:0: C0114: Missing module docstring (missing-module-docstring)
tournament_scoreboard.py:11:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:11:0: C0103: Function name "addTeam" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:11:12: C0103: Argument name "teamName" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:11:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
tournament_scoreboard.py:16:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:16:0: C0103: Function name "matchResult" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:16:16: C0103: Argument name "homeGoals" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:16:27: C0103: Argument name "awayGoals" doesn't conform to snake_case naming style
(invalid-name)
```

```
tournament_scoreboard.py:17:4: R1705: Unnecessary "elif" after "return", replace only that "elif" with "if"
(no-else-return)
tournament_scoreboard.py:25:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:25:0: C0103: Function name "recordMatch" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:25:28: C0103: Argument name "homeGoals" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:25:39: C0103: Argument name "awayGoals" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:42:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:42:11: C0103: Argument name "teamName" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:47:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:47:0: C0103: Function name "goalDifference" doesn't conform to snake_case naming
style (invalid-name)
tournament_scoreboard.py:47:19: C0103: Argument name "teamName" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:51:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:51:0: C0103: Function name "leagueTable" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:56:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:56:0: C0103: Function name "isTopTwo" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:56:13: C0103: Argument name "teamName" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:58:11: R1714: Consider merging these comparisons with 'in' by using 'teamName in
(table[0], table[1])'. Use a set instead if elements are hashable. (consider-using-in)
tournament_scoreboard.py:60:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:60:0: C0103: Function name "tossCoin" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:64:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:64:0: C0103: Function name "tableFilePath" doesn't conform to snake_case naming
style (invalid-name)
tournament_scoreboard.py:69:0: C0116: Missing function or method docstring (missing-function-docstring)
tournament_scoreboard.py:69:0: C0103: Function name "publishTable" doesn't conform to snake_case naming style
(invalid-name)
tournament_scoreboard.py:74:0: C0116: Missing function or method docstring (missing-function-docstring)


--------------------------------------------------------------------
Your code has been rated at 4.75/10 (previous run: 4.75/10, +0.00)
```

10.2 bandit_before.txt

```
Run started:2026-10-30 18:14:25.686102+00:00


Test results:
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'referee-demo'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\tournament_scoreboard.py:6:19
5    POINTS = {"win" : 3, "draw": 1, "loss": 0}
6    REFEREE_PASSWORD = "referee-demo"
7    teams = {}


--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic
purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\tournament_scoreboard.py:61:11
60    def tossCoin():
61        return random.choice(["Heads", "Tails"])
62


--------------------------------------------------
>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).
   Severity: Medium   Confidence: High
   CWE: CWE-377 (https://cwe.mitre.org/data/definitions/377.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q
   Location: .\tournament_scoreboard.py:66:11
65        # Helper kept for the lab: not called by the demo
66        return tempfile.mktemp(suffix=".json")
67
```

```
--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected,
security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\tournament_scoreboard.py:71:4
70        # Helper kept for the lab: not called by the demo
71        os.system("scp table.json " + server + ":/var/www/")
72


--------------------------------------------------


Code scanned:
    Total lines of code: 66
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0


Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 2
        Medium: 1
        High: 1
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 1
        High: 3
Files skipped (0):
```

10.3 flake8_before.txt

```
tournament_scoreboard.py:5:16: E203 whitespace before ':'
tournament_scoreboard.py:60:1: E302 expected 2 blank lines, found 1
tournament_scoreboard.py:79:51: E231 missing whitespace after ','
tournament_scoreboard.py:87:43: E261 at least two spaces before inline comment
```

10.4 pylint_after.txt

```


-------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.75/10, +5.25)
```

10.5 bandit_after.txt

```
Run started:2026-10-30 18:25:36.513129+00:00


Test results:
    No issues identified.


Code scanned:
    Total lines of code: 87
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 2


Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

10.6 flake8_after.txt

```
(empty file: Flake8 reported no warnings)
```